3.7 Attack models for authentication

There are many attack vectors for authentication, and covering them in detail is beyond the scope of this book, but we should talk about them briefly before comparing different authentication methods. We've mentioned a few, like phishing, already. Table 3.2 provides a concise description of common attack models and risks for different authentication methods along with suggested mitigation strategies.

Table 3.2 Common attack models targeting authentication systems and the methods they exploit. This table details each attack type, highlights the most vulnerable authentication methods, and suggests strategies for mitigation to improve resilience and reduce risk.

Attack Type	Description	Vulnerable Methods	Mitigation Strategies
Phishing	Trick user into revealing credentials via fake login pages or messages.	Passwords, OTP via SMS or email	Passkeys, FIDO2/WebAuthn, phishing-resistant MFA, user training
Credential Stuffing	Use stolen username/password combos from other breaches.	Password-based logins	MFA, rate limiting, breached password detection
Replay Attacks	Intercept and reuse authentication messages or tokens.	OTPs, bearer tokens	Challenge-response protocols, short token lifetimes, TLS
Man-in-the-Middle	Intercept communication between user and service.	All methods if TLS is not enforced or implemented end-to-end	TLS with certificate validation, mutual TLS, signed challenges
SIM Swapping	Hijack a phone number to intercept SMS OTPs.	SMS-based 2FA	App-based authenticators, hardware tokens
MFA Fatigue Attacks	Send repeated push notifications to annoy user into accepting an auth request.	Push-based MFA	Rate limiting, number matching, intelligent notification controls
Session Hijacking	Steal session token from browser or memory to impersonate a user.	Token-based authentication	Token binding, session expiration, re-auth for sensitive actions

You'll see how these attack methods come into play as we discuss authentication strength in the next two sections.